

PROJET BONUS

Sécurité des bases de données

OPÉRATION BLACKVAULT

Concevoir, sécuriser et piéger une base de données de gestion de secrets classifiés

Epreuve individuelle | Durée : 1 mois

Hakim Loumi - Kyrion-CS

Otéria

2025-2026

1. Contexte général

Le Bureau National de Protection des Témoins (BNPT) est une agence gouvernementale chargée de protéger et relocaliser des témoins sensibles impliqués dans des affaires de criminalité organisée, terrorisme, corruption d'État ou trafic international.

Chaque témoin peut disposer :

- d'une identité réelle ;
- d'une identité de couverture ;
- d'une ou plusieurs localisations sécurisées ;
- d'un agent de protection ;
- d'affaires judiciaires associées ;
- de menaces suivies ;
- de contacts autorisés ;
- d'évaluations de risque régulières.

La compromission d'une seule information critique peut mettre une vie en danger.

L'objectif du projet est de construire une base Oracle cohérente, puis d'y intégrer plusieurs mécanismes de Data Deception destinés à piéger, ralentir, tracer ou désinformer un attaquant ayant compromis un compte utilisateur.

2. Travail demandé

Chaque étudiant doit réaliser individuellement :

Livrable A - Modélisation

Produire le MLD correspondant au cahier des charges, avec entre 12 et 20 tables métier et sécurité, hors tables de leurre. **Fournir le fichier Looping (.loo).**

Le MLD attendu doit contenir :

- les tables ;
- les clés primaires ;
- les clés étrangères ;
- les cardinalités ;
- les contraintes principales ;
- les types Oracle proposés.

Livrable B - Implémentation Oracle SQL

Fournir les **scripts SQL** permettant :

- la création des tables ;
- la création des contraintes ;
- la création des séquences si nécessaire ;
- le chargement de données fictives (au moins 100 lignes dans les tables principales) ;
- des données cohérentes entre elles.

Les données doivent être fictives. Aucun nom réel, aucune adresse réelle, aucune donnée personnelle réelle ne doit être utilisée.

Livrable C - PL/SQL

Fournir les **scripts PL/SQL** :

- 1 fonction utile au système ;
- 1 procédure utile au système.

Exemples possibles :

- fonction de calcul du score de risque d'un témoin ;
- fonction de génération d'une signature de Watermark ;
- fonction de vérification d'habilitation ;
- procédure de relocalisation d'un témoin ;
- procédure d'ajout d'une évaluation de risque ;
- procédure de changement d'identité de couverture.

Livrable D - Data Deception

Fournir les **scripts SQL** permettant de mettre en œuvre obligatoirement les 4 techniques suivantes :

1. HoneyToken avec FGA ;
2. Vues avec public synonym pointant vers des tables de leurre selon l'utilisateur connecté ;
3. Watermarking ;
4. Polyinstanciation.

Ainsi que le scénario Red/Blue team qui explique comment ces techniques sont mises en place.

3. Spécifications fonctionnelles

La base de données doit permettre de gérer les éléments suivants.

3.1 Programmes de protection

Le système doit gérer plusieurs programmes de protection.

Chaque programme possède :

- un nom ;
- un pays ;
- une description ;
- une date de création ;
- un statut : ACTIF, SUSPENDU, ARCHIVE.

3.2 Témoins protégés

Le système doit gérer les témoins pris en charge par le BNPT.

Chaque témoin possède :

- un numéro de dossier unique ;
- une date d'entrée dans le programme ;
- un niveau de risque : FAIBLE, MODERE, ELEVE, CRITIQUE ;
- un statut : ACTIF, RELOCALISE, SORTI, DECEDE ;
- un programme de rattachement.

3.3 Identités réelles

Chaque témoin possède une identité réelle.

L'identité réelle contient :

- nom ;
- prénom ;
- date de naissance ;
- nationalité ;
- numéro d'identité national fictif ;
- empreinte ou hash de vérification.

Ces informations sont Top Secret.

3.4 Identités de couverture

Un témoin peut avoir une ou plusieurs identités de couverture.

Une identité de couverture contient :

- nom de couverture ;
- prénom de couverture ;
- date de naissance de couverture ;
- profession de couverture ;
- date d'attribution ;
- statut actif ou inactif.

3.5 Localisations sécurisées

Le système doit suivre les localisations successives d'un témoin.

Une localisation contient :

- type de lieu : SAFE_HOUSE, APPARTEMENT, HOTEL, ETRANGER ;
- ville ;
- pays ;
- adresse fictive ;
- date de début ;
- date de fin ;
- indicateur actif.

3.6 Affaires judiciaires

Le système doit gérer les affaires liées aux témoins.

Une affaire contient :

- référence unique ;
- titre ;
- type : CRIME_ORGANISE, TERRORISME, CORRUPTION, TRAFIC, AUTRE ;
- juridiction ;
- date d'ouverture ;
- statut.

Un témoin peut être lié à plusieurs affaires.

Une affaire peut impliquer plusieurs témoins.

3.7 Menaces

Le système doit gérer les menaces identifiées contre les témoins.

Une menace contient :

- témoin concerné ;
- source de la menace ;
- type : ASSASSINAT, INTIMIDATION, ENLEVEMENT, CYBERATTAQUE ;
- niveau de gravité ;
- date de détection ;
- statut ;
- détails.

3.8 Agents de protection

Le système doit gérer les agents de protection.

Un agent possède :

- matricule ;
- nom ;
- prénom ;
- grade ;
- habilitation ;
- statut ;
- username Oracle associé.

3.9 Assignations

Un agent peut être assigné à un ou plusieurs témoins.

Une assignation contient :

- témoin ;
- agent ;
- date de début ;
- date de fin ;
- rôle : PRINCIPAL, SECONDAIRE, SURVEILLANCE.

3.10 Contacts autorisés

Chaque témoin peut avoir des contacts autorisés.

Un contact contient :

- nom du contact ;
- lien avec le témoin ;
- moyen de contact ;
- fréquence autorisée ;
- agent ayant approuvé le contact.

3.11 Documents d'identité

Chaque identité de couverture peut disposer de documents fictifs.

Un document contient :

- type : CNI, PASSEPORT, PERMIS, CARTE_VITALE ;
- numéro ;
- date d'émission ;
- date d'expiration ;
- autorité d'émission.

3.12 Transferts

Le système doit suivre les transferts d'un témoin d'une localisation vers une autre.

Un transfert contient :

- témoin ;
- localisation de départ ;
- localisation d'arrivée ;
- date de transfert ;
- motif ;
- agent ayant autorisé ;
- statut.

3.13 Évaluations de risque

Le système doit conserver les évaluations périodiques de risque.

Une évaluation contient :

- témoin ;
- date d'évaluation ;
- score de risque entre 0 et 100 ;
- évaluateur ;
- commentaire ;
- date de prochaine évaluation.

3.14 Communications

Le système doit tracer les communications autorisées.

Une communication contient :

- témoin ;
- contact ;
- date ;
- type ;
- durée ;
- agent superviseur ;
- notes.

3.15 Utilisateurs applicatifs

Le système doit gérer les utilisateurs fonctionnels.

Chaque utilisateur possède :

- username ;
- rôle : ADMIN, ANALYSTE, COORDINATEUR, DIRECTEUR ;
- habilitation : PUBLIC, CONFIDENTIEL, SECRET, TOP_SECRET ;

- statut actif.

3.16 Logs et alertes

Le système doit conserver :

- les logs de connexion ;
- les logs d'accès sensibles ;
- les alertes de sécurité.

Ces tables serviront aussi aux mécanismes de Data Deception.

4. Classification Bell-LaPadula / Biba

4.1 Rappel Bell-LaPadula

Bell-LaPadula protège la confidentialité.

Règles principales :

- No Read Up : un utilisateur ne peut pas lire au-dessus de son niveau d'habilitation ;
- No Write Down : un utilisateur ne peut pas écrire vers un niveau inférieur.

4.2 Rappel Biba

Biba protège l'intégrité.

Règles principales :

- No Read Down : un processus de haute intégrité ne doit pas lire des données de basse intégrité ;
- No Write Up : un processus de basse intégrité ne doit pas écrire dans des données de haute intégrité.

4.3 Classification attendue

Table	Bell-LaPadula	Biba	Justification
PROGRAMMES_PROTECTION	Public	Haute	Informations générales
TEMOINS	Secret	Haute	Données sensibles de dossier
IDENTITES_REELLES	Top Secret	Haute	Fuite = danger vital
NOUVELLES_IDENTITES	Secret	Haute	Identité de couverture
LOCALISATIONS	Top Secret	Haute	Localisation physique critique
AFFAIRES	Confidentiel	Haute	Données judiciaires
TEMOINS_AFFAIRES	Confidentiel	Haute	Liaison témoin-affaire
MENACES	Secret	Haute	Données opérationnelles sensibles
AGENTS_PROTECTION	Confidentiel	Haute	Personnel interne
ASSIGNATIONS	Secret	Haute	Lie un agent à un témoin
CONTACTS_AUTORISES	Top Secret	Haute	Peut révéler l'identité réelle
DOCUMENTS_IDENTITE	Secret	Haute	Documents de couverture
TRANSFERTS	Top Secret	Haute	Déplacements critiques

Table	Bell-LaPadula	Biba	Justification
EVALUATIONS_RISQUE	Confidentiel	Haute	Analyse interne
COMMUNICATIONS	Secret	Basse	Traces fréquentes
UTILISATEURS	Confidentiel	Haute	Comptes applicatifs
LOG_CONNEXIONS	Public	Basse	Logs techniques
LOG_ACCES_SENSIBLES	Confidentiel	Basse	Audit automatique
ALERTES_SECURITE	Confidentiel	Basse	Alertes automatiques

5. Matrice d'accès

Table	ADMIN	ANALYSTE	COORDINATEUR	DIRECTEUR
PROGRAMMES_PROTECTION	R	R	R	R/W
TEMOINS	-	V	R/W	R/W/D
IDENTITES_REELLES	-	-	-	R
NOUVELLES_IDENTITES	-	-	R/W	R/W
LOCALISATIONS	-	-	R/W	R/W
AFFAIRES	-	R	R	R/W/D
TEMOINS_AFFAIRES	-	R	R/W	R/W/D
MENACES	-	R/W	R	R/W/D
AGENTS_PROTECTION	-	R	R/W	R/W/D
ASSIGNATIONS	-	-	R/W	R/W/D
CONTACTS_AUTORISES	-	-	R/W	R/W
DOCUMENTS_IDENTITE	-	-	R/W	R/W
TRANSFERTS	-	-	R/W	R/W
EVALUATIONS_RISQUE	-	R/W	R	R/W
COMMUNICATIONS	-	R	R	R/W
UTILISATEURS	R/W/D	-	-	R
LOG_CONNEXIONS	R	-	-	R
LOG_ACCES_SENSIBLES	R	-	-	R
ALERTES_SECURITE	R	-	-	R

Légende :

- R = lecture ;
- W = écriture ;
- D = suppression ;
- V = accès uniquement via vue masquée ;

6. Relations principales attendues

- PROGRAMMES_PROTECTION 1,N TEMOINS
- TEMOINS 1,1 IDENTITES_REELLES
- TEMOINS 1,N NOUVELLES_IDENTITES
- TEMOINS 1,N LOCALISATIONS
- TEMOINS N,N AFFAIRES via TEMOINS_AFFAIRES
- TEMOINS 1,N MENACES
- TEMOINS 1,N ASSIGNATIONS
- TEMOINS 1,N CONTACTS_AUTORISES
- TEMOINS 1,N TRANSFERTS
- TEMOINS 1,N EVALUATIONS_RISQUE
- TEMOINS 1,N COMMUNICATIONS
- AGENTS_PROTECTION 1,N ASSIGNATIONS
- AGENTS_PROTECTION 1,N CONTACTS_AUTORISES
- AGENTS_PROTECTION 1,N TRANSFERTS
- AGENTS_PROTECTION 1,N EVALUATIONS_RISQUE
- AGENTS_PROTECTION 1,N COMMUNICATIONS
- NOUVELLES_IDENTITES 1,N DOCUMENTS_IDENTITE
- CONTACTS_AUTORISES 1,N COMMUNICATIONS
- LOCALISATIONS 1,N TRANSFERTS

7. Partie Data Deception obligatoire

7.1 HoneyToken avec FGA

L'étudiant doit créer au moins un faux enregistrement très attractif.

Exemples :

- témoin avec niveau de risque CRITIQUE ;
- dossier nommé AEGIS-OMEGA ;
- fausse identité réelle très sensible ;
- fausse localisation ultra-confidentielle.

Cet enregistrement doit être marqué comme honeypot.

Tout accès à cet enregistrement doit déclencher une règle FGA avec DBMS_FGA.ADD_POLICY.

L'accès doit créer une trace dans une table de log ou d'alerte.

Attendu :

- création du honeypot ;
- politique FGA ;
- démonstration par SELECT ;
- preuve de l'alerte générée.

7.2 Polyinstanciation

L'étudiant doit créer une situation où deux utilisateurs ne voient pas la même version logique d'une donnée sensible.

Exemple :

- le DIRECTEUR voit la vraie localisation ;
- le COORDINATEUR voit une localisation opérationnelle ;
- l'ANALYSTE voit une version banalisée ;
- un utilisateur suspect voit une fausse localisation.

Cette polyinstanciation peut être réalisée avec :

- une table contenant plusieurs versions d'une donnée ;
- une colonne de niveau d'habilitation ;
- une vue filtrée selon `SYS_CONTEXT('USERENV','SESSION_USER')` ;
- ou une fonction de contrôle d'habilitation.

Attendu :

- même id_temoin ;
- plusieurs versions de localisation ou d'identité ;
- résultat différent selon l'utilisateur connecté.

7.3 Vues et public synonym vers tables de leurre

L'étudiant doit créer des tables de leurre.

Exemples :

- ADMIN_CREDENTIALS ;
- WITNESS_MASTER_LIST ;
- BACKUP_ENCRYPTION_KEYS ;
- EXPORT_TOP_SECRET ;
- MASTER_IDENTITYES.

Ces tables doivent paraître attractives pour un attaquant.

L'étudiant doit ensuite créer une vue ou un synonyme public qui redirige certains utilisateurs vers une version leurre.

Principe attendu :

- un utilisateur légitime consulte une vue sécurisée ;
- un utilisateur suspect ou non habilité est redirigé vers une vue leurre ;
- l'accès est tracé ;
- l'étudiant explique le mécanisme.

7.4 Watermarking

L'étudiant doit intégrer un mécanisme permettant d'identifier l'origine d'une fuite.

Exemple :

- lors d'un export ou d'un SELECT via une vue, certaines chaînes sont légèrement modifiées selon l'utilisateur ;
- une signature invisible ou discrète est ajoutée ;
- un registre des watermarks conserve la signature générée.

Attendu :

- table REGISTRE_WATERMARKS ;
- fonction de génération de signature ;
- vue ou procédure produisant des données watermarkées ;
- démonstration avec deux utilisateurs différents ;
- preuve que la fuite peut être rattachée à un utilisateur.

8. Contraintes techniques

Le projet doit être réalisé sous Oracle DB 26ai (FREEPDB1).

Sont attendus :

- création d'un user propriétaire du schéma principal ;
- scripts SQL fonctionnels et re-exécutables (drop + create) ;
- ordre d'exécution clair ;
- commentaires dans le code ;
- données fictives ;
- aucun GRANT ALL PRIVILEGES ;
- privilèges minimaux pour chaque user créé ;
- démonstration reproductible.

9. Rendu attendu

Chaque étudiant doit rendre :

1. Les scripts SQL :
 - 01_create_schema.sql ;
 - 02_insert_data.sql ;
 - 03_plsql.sql (pour fonction et procédure) ;
 - 04_deception.sql ;
 - 05_demo.sql (pour scénario red/Blue team).
2. une courte démonstration :
 - captures SQL ;
 - preuve des alertes ;
 - comparaison des vues selon utilisateurs ;
 - preuve du watermarking.

10. Critères d'évaluation

Total sur 50 XP :

- **Livrable A (Modélisation) : 8 points**
- **Livrable B (SQL Oracle) : 8 points**
- **Livrable C (PL/SQL) : 8 points**
- **Livrable D (Data Deception) : 26 points**